

Sesión 5

Investigación de incidente y monitoreo de backups

Del ataque a la recuperación: kill chain, MITRE ATT&CK y el blue team custodiando las copias

Investigas un ransomware real con Wazuh (SIEM) y Velociraptor (DFIR), y entregas un informe forense

Jawy Andrés Romero Pinto · Módulo 92-EAN · Universidad Ean · Educación Continua

2 horas · 1h teoría + 1h laboratorio · Sesión de cierre del módulo

Agenda de la sesión

El equipo azul: detectar el ataque, custodiar los backups, responder

OPS

Cómo operan los atacantes

El ransomware moderno es una operación: acceso, movimiento, impacto.

KILL

La kill chain y MITRE ATT&CK

La cadena de un ataque a backups, técnica por técnica.

BKP

Qué backups monitorear

Full, incremental, snapshots, WORM, offline: qué vigilar y por qué.

AZUL

Custodiar y detectar

3-2-1-1-0, inmutabilidad, FIM y el SIEM que avisa.

DFIR

SIEM + hunting

Wazuh detecta la cadena; Velociraptor confirma el backup corrupto.

LAB

Laboratorio + informe

Investigas el caso Locked3D y entregas un informe forense.

La estrella polar (el equipo azul)

La pregunta del custodio de los backups



«El atacante ya está dentro y va por los backups. ¿Cómo detecto su cadena a tiempo, protejo las copias para que no las destruya, y demuestro con evidencia qué pasó?»



Detectar la cadena

El comportamiento del ransomware lo delata en el SIEM.



Custodiar la copia

Inmutable (WORM) + monitoreada: existe y avisa si la atacan.



Probar con evidencia

Hash, entropía, YARA: qué backup sirve y cuál está corrupto.



Responder y aprender

Informe forense: timeline, MITRE, recuperación.

De la Sesión 4 a la Sesión 5

De construir la bóveda a investigar el ataque y custodiarla

Sesión 4 · bóveda inmutable

- Construiste la copia WORM que resiste el borrado
- Sabes DESDE DÓNDE restaurar
- La protección existe
- Pero ¿cómo te enteras de que te atacan? ¿qué pasó?



Sesión 5 · investigación y monitoreo

- Detectas la kill chain en el SIEM (Wazuh)
- Cazas el backup corrupto con DFIR (Velociraptor)
- Monitoreas la bóveda: el SIEM avisa del ataque
- Respondes con un informe forense (timeline + MITRE)

Cómo operan los atacantes

El ransomware moderno no es un virus: es una **OPERACIÓN** por etapas

1 • Acceso inicial

Phishing, credenciales robadas, RDP expuesto. Entran como un usuario válido.

2 • Reconocimiento y movimiento

Buscan el Directorio Activo, los servidores... y las consolas de BACKUP.

3 • Escalada y persistencia

Roban credenciales de admin. Ahora tienen las llaves del reino.

4 • Anti-recuperación

Borran shadow copies y atacan los backups: para que TENGAS que pagar.

5 • Cifrado e impacto

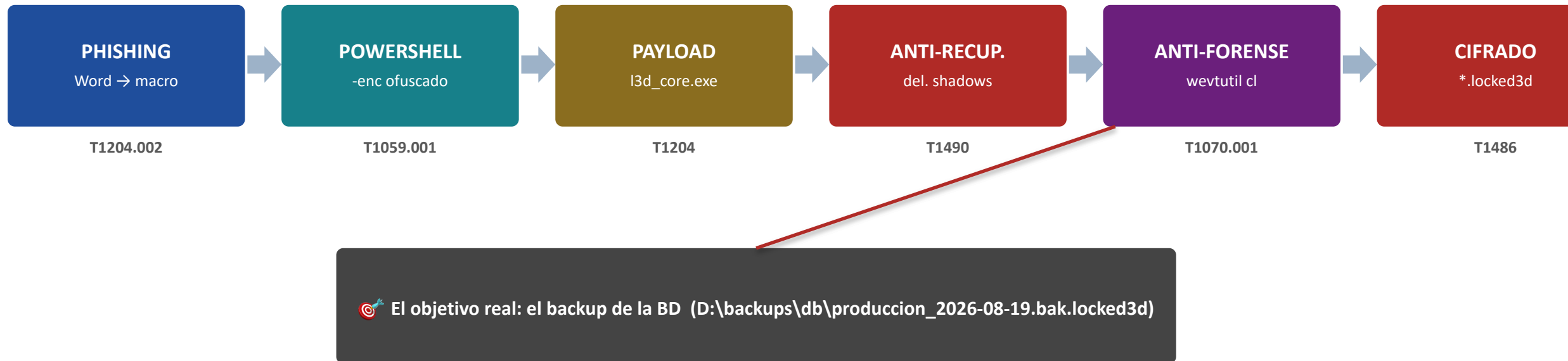
Cifran producción y backups; dejan la nota. Doble extorsión: además exfiltran.



Centro de operaciones · Wikimedia Commons · CC BY-SA 3.0

La kill chain del caso Locked3D

La cadena que investigas hoy — cada eslabón deja un rastro en el SIEM



El atacante recorre la cadena en minutos, y ANTES de cifrar producción va por la recuperación (T1490) y borra los logs (T1070.001). Cada acción genera un evento — si el SIEM ya los tiene, la cadena queda al descubierto. Esa es tu ventaja como analista.

MITRE ATT&CK: el idioma común

Mapear cada acción a una técnica te da lenguaje, detección y defensa

TÁCTICA	TÉCNICA	EN EL CASO
Ejecución	T1204.002 · Archivo malicioso	<i>El usuario abre el señuelo</i>
Ejecución	T1059.001 · PowerShell	<i>Script ofuscado -enc</i>
Impacto	T1490 · Inhibir la recuperación	<i>vssadmin / bcdedit</i>
Evasión	T1070.001 · Borrar logs de eventos	<i>wevtutil cl</i>
Impacto	T1486 · Cifrado para impacto	<i>.locked3d</i>
C2	T1071 · Protocolo de aplicación	<i>.onion</i>

Las técnicas de Impacto (T1490, T1486) son las que el atacante NO puede evitar: son su objetivo. Por eso son las más fiables para detectar — y las que el blue team vigila sobre los backups.

Por qué el backup es el primer objetivo

Sin recuperación, la víctima paga. El atacante lo sabe.

93%

de los ataques de ransomware intentan
destruir los backups

T1490

«Inhibir la recuperación»: shadow copies,
catálogos, consolas de backup

1ero

los backups se atacan ANTES de cifrar
producción

1

copia inmutable + monitoreada basta para
no pagar

La consecuencia para el equipo azul:

- El backup dejó de ser 'la última red de seguridad' y pasó a ser un ACTIVO que se ataca activamente. Hay que custodiarlo como se custodia producción.
- Custodiar = inmutabilidad (no se puede destruir) + monitoreo (el SIEM avisa del intento) + verificación (sabes que la copia sirve).

Fuente: Veeam Ransomware Trends 2023 (cifras redondeadas).

Qué tipos de backup hay que monitorear

No todos protegen igual — el blue team vigila según el riesgo

- **Full / Incremental / Diferencial**

La copia base y sus cambios. Vigila borrados masivos y cambios de programación.

- **Snapshots (ZFS, VSS, storage)**

Rápidos de restaurar, pero viven en el mismo sistema: vigila su borrado (T1490).

- **Inmutables / WORM (Object Lock)**

No se pueden alterar en su retención. Vigila intentos de borrado y de acortar la retención.

- **Offline / Air-gapped / Cinta**

Desconectados: el mejor seguro. Vigila el acceso físico y las ventanas de conexión.

- **Backups en la nube (S3, Azure)**

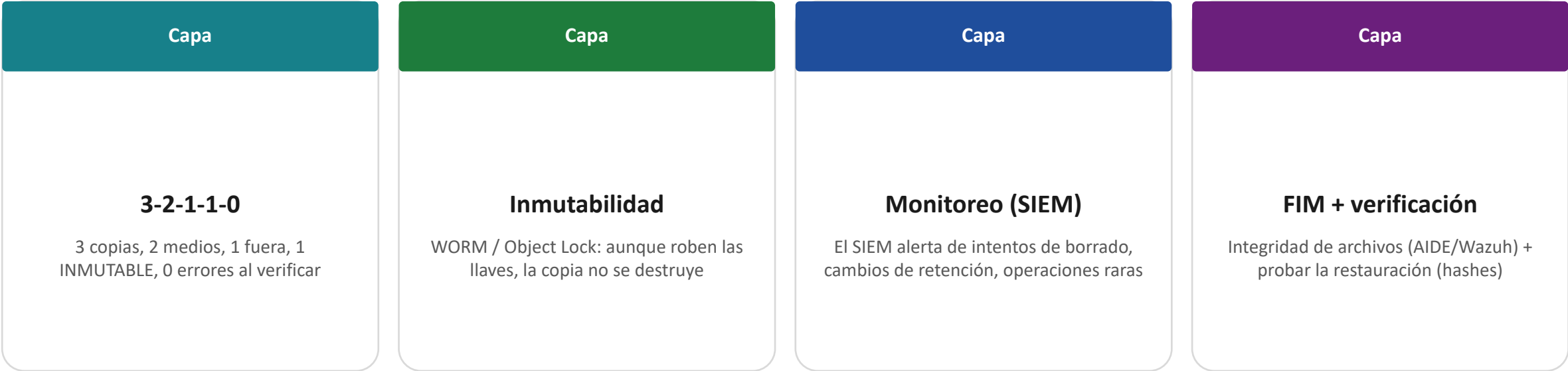
Vigila claves, políticas y borrados vía API; activa MFA-delete y versionado.



Medios de backup · Wikimedia Commons · CC BY-SA 4.0

Cómo custodia el blue team los backups

Cuatro capas — ninguna basta sola



La combinación es la clave: inmutabilidad SIN monitoreo = no sabes que te atacan; monitoreo SIN inmutabilidad = ves el ataque pero pierdes el dato. En el lab montas las dos y ves el ataque rebotar por WORM y aparecer como alerta en Wazuh.

Detectar la amenaza: el SIEM (Wazuh)

El comportamiento del ransomware lo delata — si lo sabes buscar

Lo que el ransomware DEBE hacer

- Borrar shadow copies (T1490)
- Deshabilitar la recuperación (bcdedit)
- Limpiar logs de eventos (T1070.001)
- Crear archivos cifrados en masa (T1486)
- Intentar borrar la bóveda de backups



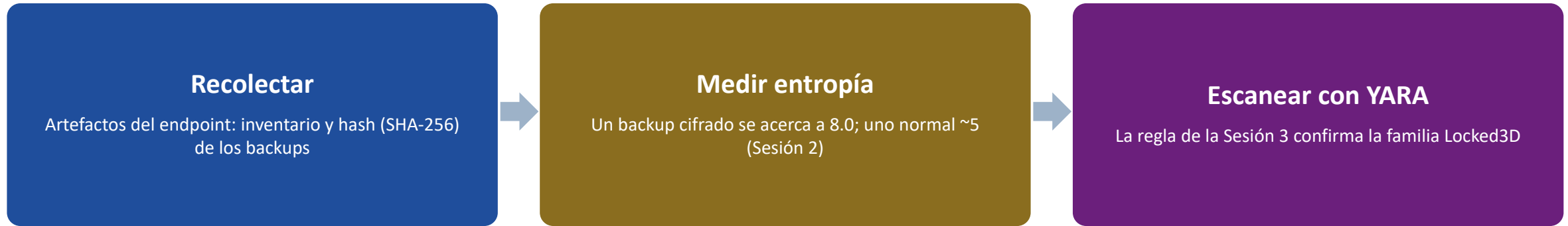
Cómo lo detecta Wazuh

- Reglas sobre esos comandos y patrones
- Cada regla mapeada a MITRE ATT&CK
- Alertas por nivel de severidad
- Correlación por host y línea de tiempo
- Monitoreo del audit-log de MinIO (bóveda)

Clave: no persigues hashes (que cambian), persigues COMPORTAMIENTO (que el atacante no puede evitar). Es lo más caro de cambiar para él — y lo más fiable para ti.

Confirmar con evidencia: DFIR (Velociraptor)

El SIEM dice 'atacaron el backup'; el hunting prueba CUÁL y con qué evidencia



El resultado que buscas — con evidencia, no con corazonadas:

- Backup CORRUPTO: produccion_2026-08-19.bak.locked3d → entropía ~8.0 + hit YARA Locked3D. Descártalo.
- Backup LIMPIO: produccion_2026-08-18.bak → entropía baja, sin hit. Restaura desde aquí, verificando hashes.
- Esa distinción, defendida con hash + entropía + YARA, es el corazón del informe. Un analista no dice 'creo': prueba.

Cuando ya hay data corrupta: cómo recuperarse

La prevención reduce el daño; el plan de recuperación lo repara — sin improvisar

1 · Confirma el alcance

Qué está corrupto/cifrado, con evidencia (entropía, hash, YARA). No restaures a ciegas.

2 · Aísla y preserva

No toques el sistema comprometido: contén la propagación y guarda la evidencia.

3 · Elige la copia limpia

La última versión INMUTABLE anterior al incidente (bóveda WORM). Nunca del host atacado.

4 · Verifica ANTES de restaurar

Hashes contra el manifiesto: el '0' de 3-2-1-1-0. Una copia sin verificar es una promesa.

5 · Restaura aislado y valida

En entorno limpio; prueba la aplicación antes de reconectar a la red.

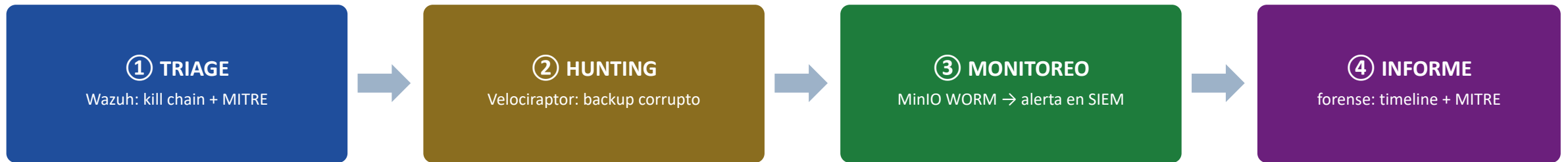
6 · Mide RTO/RPO y documenta

Cuánto tardaste y cuánto dato perdiste; queda en el informe.

La idea que se llevan: monitorear y prevenir REDUCE el daño; pero cuando el daño ya ocurrió, la recuperación confiable sale de una copia INMUTABLE y VERIFICADA, jamás del sistema atacado. Detectar rápido (SIEM) acorta el RTO; tener la copia intocable (WORM) acota el RPO.

El flujo de investigación (lab de hoy)

Cuatro fases, todas con evidencia — y todo con software libre



Cada fase alimenta la siguiente:

- El SIEM te da la cadena y el host objetivo → el hunting confirma qué copia está corrupta → el monitoreo demuestra que la bóveda avisa y resiste → el informe lo deja todo registrado para dirección y para el próximo analista.
- *Es el trabajo real de un analista de ciber-recuperación: detectar, probar, custodiar y comunicar.*

Laboratorio (2ª hora)

Investigas el caso Locked3D en el SOC del curso y entregas tu informe

Parte 1 · 25 min

Triage en Wazuh

Entras al SIEM, reconstruyes la kill chain y las técnicas MITRE, e identificas el backup objetivo.

Parte 2 · 25 min

Hunting con Velociraptor

DFIR en tu VM: identificas el backup corrupto con hash + entropía + YARA.

Parte 3 · 25 min

Monitoreo + informe

Atacas tu propia bóveda y ves la alerta; entregas el informe forense.

Entorno: Wazuh y MinIO en la nube del curso (entras por navegador con tu usuario read-only); Velociraptor corre local en tu VM. Todo el caso es sintético — la familia Locked3D es del curso, no una amenaza real.

El entregable: un informe forense

Lo que separa a un analista de un operador de herramientas

Tu informe debe contener:

- Resumen ejecutivo (para dirección, sin jerga).
- Línea de tiempo del incidente, con horas y fuentes.
- Hipótesis: las que consideraste y cuál confirmaste.
- Hallazgos: kill chain, IOCs y el backup corrupto vs limpio (con evidencia).
- Técnicas MITRE ATT&CK mapeadas a eventos reales.
- Recomendaciones de recuperación y de monitoreo.

Cómo entregarlo

- Usa la plantilla del módulo (estilo forense).
- Súbelo al repositorio en la carpeta informes/ con el nombre nombre-y-dependencia.md (o .pdf).

Ej.: juan-perez-contabilidad.md

- Un informe por persona, basado en evidencia (hashes, queries, salidas).

Cierre del módulo · el arsenal completo

Cinco sesiones, un ciclo de ciber-recuperación de punta a punta



El hilo conductor:

- Herramientas abiertas (Wazuh, Velociraptor, YARA/Sigma, MinIO): un SOC completo sin licencias.
- El comportamiento manda: se detecta lo que el atacante no puede evitar (T1490, T1486), no hashes que cambian.
- Del ataque a la recuperación confiable: detectar, custodiar lo inmutable, probar con evidencia y comunicar.

Ahora tienes un pipeline de ciber-recuperación que puedes montar y operar entero con software libre.